

PhoneP2P - Backend API Spec cho các luồng còn thiếu

Ngày cập nhật: 2026-04-28

1. Mục tiêu

Tài liệu này mô tả các API backend cần bổ sung để hoàn thiện các luồng đang có trên FE PhoneP2P:

- Checkout từ giỏ hàng sang đơn hàng.
- Sổ địa chỉ và lấy địa chỉ hiện tại qua Google Maps phía server.
- Quản lý/duyet shop.
- Permission và shop context cho admin-store.
- Quote checkout, voucher, VietQR, pickup point.
- Chat buyer/seller.
- Product review/approval.

Tài liệu ưu tiên tương thích với code hiện tại. Đặc biệt:

- API tạo đơn hiện tại là `POST /api/cart/checkout`.
- Nhóm `/api/order/*` hiện phù hợp cho quản lý đơn sau khi đơn đã được tạo.
- Không nên tạo đơn bằng `PUT /api/order/update`; endpoint đó chỉ nên dùng để cập nhật trạng thái/thông tin vận hành của đơn đã tồn tại.

2. Hiện trạng API liên quan

2.1 Cart checkout hiện có

Endpoint hiện có:

```
POST /api/cart/checkout
Authorization: Bearer <token>
Content-Type: application/json
```

Payload hiện tại:

```
{
  "addressLine": "Nguoi nhan - SDT | Dia chi giao hang | Ghi chu"
}
```

Backend hiện đã:

- Lấy user đang đăng nhập.
- Kiểm tra cart tồn tại và có item.

- Kiểm tra tồn kho từng cart item.
- Tạo `Order` với status `PENDING`.
- Set `addressDetail` từ `addressLine`.
- Set `methodTransaction` mặc định là COD.
- Tạo `OrderItem`.
- Trừ số lượng `ProductVariant`.
- Đánh dấu `CartItem` đã checkout.
- Tạo `OrderStatusHistory` ban đầu.

2.2 Order API hiện có

Base path: `/api/order`

Method	Path	Vai trò hiện tại
POST	<code>/search</code>	Admin/staff tìm kiếm đơn hàng
GET	<code>/detail/{id}</code>	Chi tiết đơn hàng
PUT	<code>/update</code>	Cập nhật trạng thái/phí ship/ghi chú xử lý
GET	<code>/history/{id}</code>	Lịch sử trạng thái đơn
POST	<code>/order-by-user</code>	Danh sách đơn theo user
POST	<code>/count-order-user</code>	Thống kê số đơn theo user
POST	<code>/count-order-staff</code>	Thống kê số đơn theo staff/admin
GET	<code>/dashboard/{searchText}</code>	Chỉ số dashboard
GET	<code>/pdf/generate/{id}</code>	Xuất PDF đơn

Kết luận: nhóm `/api/order/*` dùng tốt cho bước sau checkout. Luồng đặt đơn vẫn nên gọi `POST /api/cart/checkout` để giữ transaction cart, tồn kho và order item.

3. Quy ước chung

3.1 Response wrapper

Tất cả API trả về `CommonResponse` :

```
{
  "code": 0,
  "message": "Success",
  "errorFileLog": "",
  "data": {}
}
```

Mã code đang dùng:

Code	Ý nghĩa
0	Thành công
2	Không tìm thấy
3	Đã tồn tại
4	Lỗi business/validation
5	Lỗi account hoặc auth
12	Token hết hạn
9999	Lỗi hệ thống

3.2 Paging response

Các API search/list trả về `PageResponse<T>` trong `data` :

```
{
  "content": [],
  "page": 0,
  "size": 10,
  "totalElements": 0,
  "totalPages": 0,
  "first": true,
  "last": true
}
```

3.3 Auth và role

- Tất cả API nghiệp vụ dùng JWT Bearer token.
- Role chính: `ADMIN` , `STAFF` , `CUSTOMER` .
- Permission FE đang dùng:

```
VIEW_DASHBOARD
VIEW_ORDERS
UPDATE_ORDER_STATUS
CANCEL_ORDER
VIEW_PRODUCTS
EDIT_PRODUCTS
EDIT_PRICE
VIEW_USERS
EDIT_USERS
VIEW_SHOPS
APPROVE_SHOPS
```

3.4 Backward compatibility

- Không phá payload cũ của `POST /api/cart/checkout` .
- Nếu request chỉ có `{ "addressLine": "..."} ,` backend vẫn xử lý như hiện tại.
- Payload mới chỉ mở rộng field, không đổi endpoint tạo đơn.

4. Tổng quan endpoint cần bổ sung

Ưu tiên	Endpoint	Mục đích
P0	POST /api/cart/checkout	Mở rộng payload tạo đơn
P0	GET /api/address	Danh sách địa chỉ của user
P0	GET /api/address/default	Địa chỉ mặc định
P0	POST /api/address	Tạo địa chỉ
P0	PUT /api/address/{id}	Cập nhật địa chỉ
P0	DELETE /api/address/{id}	Xóa mềm địa chỉ
P0	PUT /api/address/{id}/default	Đặt địa chỉ mặc định
P0	POST /api/location/current-address	Lấy địa chỉ hiện tại bằng Google Maps phía BE
P0	POST /api/shop/search	Admin tìm kiếm shop
P0	GET /api/shop/{id}	Chi tiết shop
P0	PUT /api/shop/approve/{id}	Duyệt shop
P0	PUT /api/shop/reject/{id}	Từ chối shop
P0	GET /api/user/get/user-detail	Mở rộng permissions và shopContext
P0	PUT /api/user/update-permissions	Cập nhật permission cho staff
P1	POST /api/checkout/quote	Tính tạm tính/phí ship/discount
P1	GET /api/voucher/available	Voucher khả dụng
P1	POST /api/voucher/apply	Kiểm tra áp voucher
P1	POST /api/payment/vietqr/create	Tạo giao dịch VietQR
P1	GET /api/payment/{id}/status	Trạng thái thanh toán
P1	POST /api/payment/vietqr/webhook	Webhook VietQR
P1	GET /api/pickup-point/search	Danh sách điểm nhận
P2	POST /api/conversation/start	Tạo/lấy conversation
P2	GET /api/conversation	Danh sách conversation
P2	GET /api/conversation/{id}/messages	Tin nhắn
P2	POST /api/conversation/{id}/messages	Gửi tin nhắn
P2	POST /api/product/review/search	Danh sách sản phẩm chờ duyệt
P2	PUT /api/product/review/{id}/approve	Duyệt sản phẩm
P2	PUT /api/product/review/{id}/reject	Từ chối sản phẩm

5. P0 - Checkout và tạo đơn

5.1 Mở rộng `POST /api/cart/checkout`

Mục tiêu: tạo đơn từ cart với thông tin nhận hàng rõ ràng hơn, vẫn giữ transaction hiện tại.

```
POST /api/cart/checkout
Authorization: Bearer <CUSTOMER token>
Content-Type: application/json
```

Request legacy vẫn hợp lệ

```
{
  "addressLine": "Nguyen Van A - 0900000000 | 42 Nguyen Hue, Quan 1, TP.HCM"
}
```

Request mới

```
{
  "deliveryMethod": "DELIVERY",
  "recipientName": "Nguyen Van A",
  "recipientPhone": "0900000000",
  "addressId": "address-uuid",
  "addressLine": "42 Nguyen Hue, Quan 1, TP.HCM",
  "note": "Goi truoc khi giao",
  "paymentMethod": "COD",
  "voucherCode": null,
  "pickupPointId": null,
  "scheduledReceiveAt": null
}
```

Field rules

Field	Required	Rule
deliveryMethod	No	Default <code>DELIVERY</code> ; enum <code>DELIVERY</code> , <code>PICKUP</code> , <code>LATER</code>
recipientName	No	Nếu thiếu thì fallback profile fullName
recipientPhone	No	Nếu thiếu thì fallback profile phone
addressId	No	Nếu có thì phải thuộc current user
addressLine	Yes với delivery legacy	Không được rỗng khi <code>DELIVERY</code>
note	No	Tối đa 500 ký tự
paymentMethod	No	Default <code>COD</code> ; enum <code>COD</code> , <code>VIETQR</code>
voucherCode	No	Chỉ áp dụng khi voucher API hoàn tất
pickupPointId	Yes với <code>PICKUP</code>	Phải tồn tại và active
scheduledReceiveAt	No	Dùng cho <code>LATER</code>

Response success

```
{
  "code": 0,
  "message": "Dat hang thanh cong",
  "data": {
    "orderId": "order-uuid",
    "orderCode": "ORDER-123456",
    "status": "PENDING",
    "totalAmount": 12990000,
    "shippingFee": null,
    "paymentMethod": "COD",
    "paymentStatus": "UNPAID"
  }
}
```

Business rules

- Chỉ `CUSTOMER` được checkout cart của chính mình.
- Cart rỗng trả `code = 2` .
- Item đã xóa hoặc inactive không được checkout.
- Nếu tồn kho không đủ, trả lỗi business kèm danh sách item lỗi.
- Tạo order, order item, trừ tồn kho và clear cart trong cùng transaction.
- COD tạo order `PENDING` .
- VietQR có thể tạo order `PENDING_PAYMENT` hoặc giữ `PENDING` kèm `statusTransaction = PENDING` , tùy model BE chọn; FE chỉ cần response rõ `paymentStatus` .
- Nếu dùng `addressId` , backend lấy `addressLine` tại thời điểm checkout và copy vào order để tránh thay đổi lịch sử khi user sửa địa chỉ sau này.

- Không lưu tọa độ GPS vào order trong v1.

Error cases

Case	Code	Message gợi ý
Chưa đăng nhập	5 hoặc 12	Vui long dang nhap de thanh toan
Cart rỗng	2	Gio hang khong co san pham
Thiếu địa chỉ delivery	4	Vui long nhap dia chi giao hang
Address không thuộc user	4	Dia chi khong hop le
Hết hàng	4	Mot so san pham khong du ton kho
Voucher không hợp lệ	4	Voucher khong hop le

FE sử dụng

- `/checkout`
- `/cart-screen` chuyển sang checkout
- Sau success điều hướng về `/settings/{id}/overview`

Acceptance tests

- Payload cũ `{ addressLine }` vẫn tạo đơn thành công.
- Payload mới delivery tạo đơn, copy đúng recipient/address/note.
- Pickup không bắt `addressLine`, bắt `pickupPointId`.
- Tồn kho bị trừ đúng và cart item bị checkout.
- Khi lỗi tồn kho, không tạo order và không trừ item nào.

5.2 DB impact gợi ý cho order

Hiện `Order` đã có `addressDetail`, `methodTransaction`, `description`, `statusTransaction`, `shippingFee`.

Để hỗ trợ payload mới rõ ràng hơn, BE nên cân nhắc thêm cột:

Column	Type gợi ý	Ghi chú
delivery_method	varchar(30)	DELIVERY , PICKUP , LATER
recipient_name	nvarchar(255)	Snapshot lúc checkout
recipient_phone	varchar(30)	Snapshot lúc checkout
payment_method	varchar(30)	COD , VIETQR
voucher_code	varchar(100)	nullable
discount_amount	decimal	default 0
pickup_point_id	varchar(50)	nullable
scheduled_receive_at	datetimeoffset	nullable

Nếu chưa muốn migration lớn, v1 có thể tiếp tục encode vào `addressDetail` và `description`, nhưng response nên trả DTO rõ ràng cho FE.

6. P0 - Address book

Entity `Address` đã tồn tại nhưng chưa có controller. Cần bổ sung controller/service/repository scope theo current user.

6.1 Address DTO

```
{
  "id": "address-uuid",
  "addressLine": "42 Nguyen Hue, Ben Nghe, Quan 1",
  "city": "TP.HCM",
  "district": "Quan 1",
  "postalCode": "700000",
  "isDefault": true,
  "createdAt": "2026-04-28T10:00:00+07:00",
  "updatedAt": "2026-04-28T10:00:00+07:00"
}
```

6.2 GET /api/address

```
GET /api/address
Authorization: Bearer <CUSTOMER token>
```

Response:

```
{
  "code": 0,
  "message": "Success",
  "data": [
    {
      "id": "address-uuid",
      "addressLine": "42 Nguyen Hue, Quan 1, TP.HCM",
      "city": "TP.HCM",
      "district": "Quan 1",
      "postalCode": "700000",
      "isDefault": true
    }
  ]
}
```

Rules:

- Chỉ trả địa chỉ của current user.
- Sort default trước, sau đó updatedAt desc.

6.3 GET /api/address/default

```
GET /api/address/default
Authorization: Bearer <CUSTOMER token>
```

Rules:

- Nếu chưa có default nhưng có address, trả address mới nhất.
- Nếu chưa có address, trả `data = null`, `code = 0`.

6.4 POST /api/address

```
POST /api/address
Authorization: Bearer <CUSTOMER token>
Content-Type: application/json
```

Request:

```
{
  "addressLine": "42 Nguyen Hue, Quan 1, TP.HCM",
  "city": "TP.HCM",
  "district": "Quan 1",
  "postalCode": "700000",
  "isDefault": true
}
```

Rules:

- `addressLine` required.
- Nếu `isDefault = true`, unset default của address khác cùng user.
- Nếu đây là address đầu tiên của user, tự set default.

6.5 PUT /api/address/{id}

Request giống create.

Rules:

- Không cho update address của user khác.
- Nếu set default thì unset default cũ.

6.6 DELETE /api/address/{id}

Rules:

- Xóa mềm nếu entity có `isDeleted`; nếu chưa có thì hard delete cũng được trong v1.
- Không cho xóa address của user khác.
- Nếu xóa default, tự chọn address còn lại mới nhất làm default.

6.7 PUT /api/address/{id}/default

Rules:

- Address phải thuộc current user.
- Chỉ một default address/user.

Acceptance tests

- User A không đọc/sửa/xóa address của User B.
- Tạo address đầu tiên tự thành default.
- Set default mới làm default cũ chuyển false.
- Checkout bằng `addressId` chỉ nhận address thuộc user hiện tại.

7. P0 - Server-side Google Maps location

7.1 POST /api/location/current-address

Mục tiêu: FE bấm "Lấy vị trí hiện tại", backend gọi Google Maps bằng server key và chỉ trả về địa chỉ text. Không trả tọa độ cho FE.

```
POST /api/location/current-address
Authorization: Bearer <CUSTOMER token>
Content-Type: application/json
```

Request v1:

```
{
  "considerIp": true
}
```

Response:

```
{
  "code": 0,
  "message": "Success",
  "data": {
    "address": "Quan 1, Thanh pho Ho Chi Minh, Viet Nam",
    "source": "GOOGLE_MAPS",
    "accuracyMeters": 1200
  }
}
```

Rules:

- Backend đọc env `GOOGLE_MAPS_API_KEY`.
- Không log API key.
- Không trả `lat`, `lng` về FE.
- Không lưu location tự động vào profile/address.
- Nếu Google không trả địa chỉ rõ, trả `code = 4`.

Lưu ý kỹ thuật:

- Google Geolocation API nội bộ vẫn trả `lat/lng`; BE chỉ dùng tạm để gọi Geocoding API lấy `formatted_address`.
- Nếu FE không gửi browser GPS/cell/wifi signal, Google chủ yếu định vị theo IP nên độ chính xác hạn chế. Đây là tradeoff để đáp ứng yêu cầu "không lấy tọa độ" ở payload/public response.

Error cases:

Case	Code	Message gợi ý
Thiếu key	9999	Google Maps key is not configured
Google quota/rate limit	4	Không thể lấy địa chỉ hiện tại
Không có formatted address	4	Google không tra về địa chỉ rõ ràng

FE sử dụng:

- `/checkout` , nút lấy vị trí cạnh "Địa chỉ giao hàng".

Acceptance tests:

- API không trả field `lat` hoặc `lng` .
- Thiếu key không expose secret trong message/log.
- Google fail thì FE vẫn cho nhập địa chỉ thủ công.

8. PO - Shop approval

Backend hiện có `POST /api/shop/register` ; cần bổ sung API để admin xem và duyệt shop.

8.1 Shop list item

```
{
  "id": "shop-registration-uuid",
  "shopName": "Phone Store A",
  "description": "Chuyen iPhone cu",
  "status": "PENDING",
  "ownerId": "user-uuid",
  "ownerName": "Nguyen Van A",
  "avatarUrl": "uploads/shop/avatar.png",
  "bannerUrl": "uploads/shop/banner.png",
  "cccdUrl": "uploads/shop/cccd.png",
  "createdAt": "2026-04-28T10:00:00+07:00",
  "rejectionReason": null
}
```

8.2 `POST /api/shop/search`

```
POST /api/shop/search
Authorization: Bearer <ADMIN or VIEW_SHOPS token>
Content-Type: application/json
```

Request:

```
{
  "searchText": "phone",
  "status": "PENDING",
  "page": 0,
  "size": 10
}
```

Response:

```
{
  "code": 0,
  "message": "Success",
  "data": {
    "content": [],
    "page": 0,
    "size": 10,
    "totalElements": 0,
    "totalPages": 0,
    "first": true,
    "last": true
  }
}
```

Rules:

- `status`: `PENDING`, `APPROVED`, `REJECTED`; null nghĩa là all.
- `searchText` search theo shopName, owner username, owner fullName.
- Chỉ admin hoặc user có permission `VIEW_SHOPS`.

8.3 GET /api/shop/{id}

```
GET /api/shop/{id}
Authorization: Bearer <ADMIN or VIEW_SHOPS token>
```

Response `data` gồm:

- Thông tin shop registration.
- Owner summary.
- Payment methods.
- File URLs: avatar, banner, cccd.
- Product count nếu có.

8.4 PUT /api/shop/approve/{id}

```
PUT /api/shop/approve/{id}
Authorization: Bearer <ADMIN or APPROVE_SHOPS token>
```

Rules:

- Chỉ duyệt shop **PENDING** hoặc duyệt lại shop **REJECTED** .
- Set status **APPROVED** .
- Clear **rejectionReason** .
- Đảm bảo owner có role/permission bán hàng phù hợp. Hiện code register đã set role **STAFF** ; nếu duyệt mới đổi role thì chuyển logic set role sang approve sẽ đúng hơn.

Response:

```
{
  "code": 0,
  "message": "Duyet shop thanh cong",
  "data": {
    "id": "shop-registration-uuid",
    "status": "APPROVED"
  }
}
```

8.5 PUT /api/shop/reject/{id}

```
PUT /api/shop/reject/{id}
Authorization: Bearer <ADMIN or APPROVE_SHOPS token>
Content-Type: application/json
```

Request:

```
{
  "reason": "Anh CCCD không rõ"
}
```

Rules:

- reason** required, tối đa 500 ký tự.
- Set status **REJECTED** .
- Lưu **rejectionReason** .
- Không xóa shop record hoặc file đã upload.

FE sử dụng:

- /admin-store/shops**
- Dashboard block pending shops.

Acceptance tests:

- Search trả đúng tab pending/approved/rejected.
- Không có `APPROVE_SHOPS` thì reject/approve bị từ chối.
- Reject lưu reason và detail trả lại reason.

9. P0 - Permission và shop context

9.1 Mở rộng `GET /api/user/get/user-detail`

Endpoint đã có. Cần mở rộng `data`.

Response hiện tại vẫn giữ field cũ, thêm:

```
{
  "code": 0,
  "message": "Success",
  "data": {
    "id": "user-uuid",
    "loginId": "staff01",
    "fullName": "Staff 01",
    "role": "STAFF",
    "permissions": [
      "VIEW_DASHBOARD",
      "VIEW_ORDERS",
      "UPDATE_ORDER_STATUS",
      "VIEW_PRODUCTS",
      "EDIT_PRODUCTS"
    ],
    "shopContext": {
      "shopId": "shop-registration-uuid",
      "shopName": "Phone Store A",
      "status": "APPROVED",
      "ownerId": "user-uuid"
    }
  }
}
```

Rules:

- `permissions` lấy từ DB nếu đã có bảng permission; nếu chưa có thì derive theo role.
- `shopContext` trả shop approved/pending mới nhất của user nếu user là staff/shop owner.
- Customer có thể trả `permissions = []`, `shopContext = null`.

FE sử dụng:

- `AuthContext`
- Route guard admin-store.
- Navbar admin-store hiển thị shop name.

9.2 PUT /api/user/update-permissions

PUT /api/user/update-permissions

Authorization: Bearer <ADMIN or EDIT_USERS token>

Content-Type: application/json

Request:

```
{
  "userId": "staff-user-uuid",
  "permissions": [
    "VIEW_ORDERS",
    "UPDATE_ORDER_STATUS",
    "VIEW_PRODUCTS"
  ]
}
```

Response:

```
{
  "code": 0,
  "message": "Cap nhât quyền thành công",
  "data": {
    "userId": "staff-user-uuid",
    "permissions": [
      "VIEW_ORDERS",
      "UPDATE_ORDER_STATUS",
      "VIEW_PRODUCTS"
    ]
  }
}
```

Rules:

- Chỉ admin hoặc user có `EDIT_USERS` .
- Không cho tự gỡ quyền cuối cùng khiến tài khoản admin hiện tại mất quyền quản trị nếu đó là admin duy nhất.
- Validate permission name thuộc allowlist FE đang dùng.
- Nếu user role `CUSTOMER` , không cho gán admin-store permission.

DB gợi ý:

- `permissions(id, code, description)`
- `user_permissions(user_id, permission_id)`

Acceptance tests:

- Update permission xong login/get-user-detail trả đúng permission mới.
- Permission lạ trả `code = 4` .

- Staff không có `EDIT_USERS` không gọi được.

10. P1 - Checkout quote

10.1 `POST /api/checkout/quote`

Mục tiêu: FE biết tổng tiền, phí ship, discount trước khi tạo order.

```
POST /api/checkout/quote
Authorization: Bearer <CUSTOMER token>
Content-Type: application/json
```

Request:

```
{
  "deliveryMethod": "DELIVERY",
  "addressId": "address-uuid",
  "addressLine": "42 Nguyen Hue, Quan 1, TP.HCM",
  "voucherCode": "PHONEP2P50",
  "pickupPointId": null
}
```

Response:

```
{
  "code": 0,
  "message": "Success",
  "data": {
    "subtotal": 12990000,
    "shippingFee": 30000,
    "discountAmount": 50000,
    "totalAmount": 12970000,
    "lineItems": [
      {
        "cartItemId": "cart-item-uuid",
        "productName": "iPhone 14",
        "quantity": 1,
        "unitPrice": 12990000,
        "amount": 12990000
      }
    ],
    "voucher": {
      "code": "PHONEP2P50",
      "discountAmount": 50000
    }
  }
}
```

Rules:

- Không tạo order.
- Không trừ tồn kho.
- Quote phải dùng cùng logic giá với checkout.
- Checkout nên re-calculate lại quote server-side, không tin total từ FE.

FE sử dụng:

- `/checkout` summary.

Acceptance tests:

- Quote không thay đổi cart.
- Voucher invalid trả lỗi nhưng không checkout.
- Total = subtotal + shippingFee - discountAmount.

11. P1 - Voucher

11.1 Voucher DTO

```
{
  "code": "PHONEP2P50",
  "title": "Giảm 50K",
  "description": "Áp dụng cho đơn từ 1 triệu",
  "discountType": "FIXED",
  "discountValue": 50000,
  "minSubtotal": 1000000,
  "maxDiscount": 50000,
  "startsAt": "2026-04-01T00:00:00+07:00",
  "endsAt": "2026-05-01T00:00:00+07:00"
}
```

11.2 GET /api/voucher/available

```
GET /api/voucher/available
Authorization: Bearer <CUSTOMER token>
```

Response:

```
{
  "code": 0,
  "message": "Success",
  "data": []
}
```

Rules:

- Chỉ trả voucher active, chưa hết hạn, user có thể dùng.
- Có thể filter theo subtotal/cart current user.

11.3 POST /api/voucher/apply

```
POST /api/voucher/apply
Authorization: Bearer <CUSTOMER token>
Content-Type: application/json
```

Request:

```
{
  "code": "PHONEP2P50",
  "subtotal": 12990000
}
```

Response:

```
{
  "code": 0,
  "message": "Success",
  "data": {
    "code": "PHONEP2P50",
    "discountAmount": 50000,
    "finalSubtotal": 12940000
  }
}
```

Rules:

- Apply API chỉ kiểm tra/tính discount, không đánh dấu đã dùng.
- Checkout mới là nơi consume voucher trong transaction tạo order.

12. P1 - VietQR payment

12.1 POST /api/payment/vietqr/create

```
POST /api/payment/vietqr/create
Authorization: Bearer <CUSTOMER token>
Content-Type: application/json
```

Request:

```
{
  "orderId": "order-uuid",
  "amount": 12970000
}
```

Response:

```
{
  "code": 0,
  "message": "Success",
  "data": {
    "paymentId": "payment-uuid",
    "orderId": "order-uuid",
    "amount": 12970000,
    "status": "PENDING",
    "qrCodeUrl": "https://...",
    "qrContent": "PHONEP2P ORDER-123456",
    "expiresAt": "2026-04-28T10:15:00+07:00"
  }
}
```

Rules:

- Chỉ tạo payment cho order của current user.
- Không tạo payment nếu order đã paid/cancelled/completed.
- `amount` phải khớp order total server-side.

12.2 GET `/api/payment/{id}/status`

Response:

```
{
  "code": 0,
  "message": "Success",
  "data": {
    "paymentId": "payment-uuid",
    "orderId": "order-uuid",
    "status": "PAID",
    "paidAt": "2026-04-28T10:05:00+07:00"
  }
}
```

12.3 POST `/api/payment/vietqr/webhook`

Rules:

- Xác thực chữ ký/secret từ provider.
- Idempotent theo transaction id.
- Khi paid, set payment `PAID`, order `statusTransaction = PAID`.
- Không expose webhook secret trong log.

FE sử dụng:

- `/checkout` khi chọn VietQR.
- `/settings/{id}/overview` xem trạng thái thanh toán.

13. P1 - Pickup point

13.1 GET /api/pickup-point/search

```
GET /api/pickup-point/search?searchText=&city=&active=true
Authorization: Bearer <token>
```

Response:

```
{
  "code": 0,
  "message": "Success",
  "data": [
    {
      "id": "pickup-uuid",
      "name": "PhoneP2P Hub Nguyen Hue",
      "addressLine": "Tang 2, 42 Nguyen Hue, Quan 1, TP.HCM",
      "city": "TP.HCM",
      "district": "Quan 1",
      "active": true,
      "openingHours": "09:00-18:00"
    }
  ]
}
```

Rules:

- Customer dùng để chọn pickup tại checkout.
- Admin có thể bổ sung CRUD ở phase sau:
- POST /api/pickup-point
- PUT /api/pickup-point/{id}
- DELETE /api/pickup-point/{id}

14. P2 - Chat buyer/seller

14.1 POST /api/conversation/start

```
POST /api/conversation/start
Authorization: Bearer <CUSTOMER token>
Content-Type: application/json
```

Request:

```
{
  "productId": "product-uuid",
  "sellerId": "seller-user-uuid",
  "initialMessage": "San pham nay con hang khong?"
}
```

Response:

```
{
  "code": 0,
  "message": "Success",
  "data": {
    "conversationId": "conversation-uuid",
    "productId": "product-uuid",
    "buyerId": "buyer-user-uuid",
    "sellerId": "seller-user-uuid"
  }
}
```

Rules:

- Nếu conversation buyer/seller/product đã tồn tại thì trả conversation cũ.
- Không cho user tự chat với chính mình.

14.2 GET /api/conversation

Query:

```
GET /api/conversation?page=0&size=20
```

Trả danh sách conversation của current user.

14.3 GET /api/conversation/{id}/messages

Trả message theo page.

14.4 POST /api/conversation/{id}/messages

Request:

```
{
  "content": "Con hang ban nhe",
  "attachments": []
}
```

Rules:

- Chỉ participant của conversation được đọc/gửi.
- Message tối đa 2000 ký tự.
- Phase đầu chưa cần realtime; FE có thể polling.

FE sử dụng:

- Product detail page, nút nhấn người bán.
- Có thể thêm inbox sau.

15. P2 - Product review/approval

Hiện FE có placeholder `admin-store/products/verify-products.tsx`. ProductStatus hiện có: `ACTIVE`, `INACTIVE`, `OUT_OF_STOCK`, `DISCONTINUED`, `DRAFT`.

Gợi ý bổ sung enum:

```
PENDING_REVIEW  
REJECTED
```

15.1 POST /api/product/review/search

```
POST /api/product/review/search  
Authorization: Bearer <ADMIN or VIEW_PRODUCTS token>  
Content-Type: application/json
```

Request:

```
{  
  "searchText": "iphone",  
  "status": "PENDING_REVIEW",  
  "page": 0,  
  "size": 10  
}
```

Response dùng `PageResponse<ProductListItem>`.

15.2 PUT /api/product/review/{id}/approve

Rules:

- Chỉ admin hoặc user có permission phù hợp.
- Product `PENDING_REVIEW` chuyển `ACTIVE`.
- Ghi moderation history.

15.3 PUT /api/product/review/{id}/reject

Request:

```
{
  "reason": "Anh san pham khong ro"
}
```

Rules:

- Reason required.
- Product chuyển **REJECTED**.
- Staff/shop owner xem được reason để chỉnh sửa.

DB gợi ý:

- `product_moderation_histories(id, product_id, status, reason, reviewer_id, created_at)`.

16. Security và phân quyền đề xuất

API group	CUSTOMER	STAFF	ADMIN
Cart checkout	Own cart	No	No
Address	Own address	No	Optional support read-only
Location current address	Own session	No	No
Order search/detail/history	Own order via user APIs	Scoped by shop/seller	All
Order update	No	Scoped seller orders	All
Shop search/detail	No	If VIEW_SHOPS	Yes
Shop approve/reject	No	If APPROVE_SHOPS	Yes
Permission update	No	No	Yes
Payment create/status	Own order	No	Read/admin optional
Chat	Own conversations	Own conversations	Optional moderation
Product review	No	If permission	Yes

17. Rollout đề xuất

Phase 1

- Mở rộng `POST /api/cart/checkout`.
- Address CRUD.
- Server-side location address.
- Shop search/detail/approve/reject.

- Mở rộng user detail permissions/shopContext.

Phase 2

- Checkout quote.
- Voucher.
- Pickup point.
- VietQR create/status/webhook.

Phase 3

- Chat.
- Product review/approval.
- Settings/admin config API nếu cần.

18. Test checklist tổng hợp

- Legacy checkout payload vẫn chạy.
- New checkout payload delivery/pickup/later chạy đúng.
- Checkout lỗi không tạo partial order.
- Address ownership không bị bypass.
- Location API không trả hoặc log tọa độ/API key.
- Shop approval đúng trạng thái và permission.
- User detail trả đúng permission/shopContext sau login.
- Quote không mutate cart/order.
- Voucher chỉ consume trong checkout transaction.
- VietQR webhook idempotent.
- Conversation chỉ participant đọc/gửi.
- Product review lưu lịch sử duyệt/từ chối.

19. Ghi chú cho FE

- Khi BE có `POST /api/location/current-address`, FE nên bỏ gọi Google trực tiếp bằng public key và chuyển sang gọi API BE.
- Khi BE mở rộng checkout response DTO, FE không nên phụ thuộc vào entity `Order` raw.
- Khi `permissions` trả từ BE ổn định, FE có thể bỏ fallback hardcoded theo role nếu muốn.
- Khi shop approval API hoàn tất, `/admin-store/shops` có thể bỏ empty state và nổi dữ liệu thật.